

machine to be rebooted, and are capable of turning the machine into a zombie the moment they are downloaded. Another famous injection method is to put the botnet's malicious code in the form of installable files on a USB drive, and inject the code on a machine that allows easy physical access and is vulnerable or insecure. There are a few advanced methods, such as forcing a user to run a script sent as an attachment, or hiding the code in a music file and distributing it using peer-to-peer shares.

The process mentioned above is only possible when enough security measures are not in place. For example, a machine not running anti-virus software, or running with old or dated anti-virus definitions can fall prey to this process easily. Similarly, an un-patched or improperly patched system or network can expose a lot of vulnerabilities that can be exploited. In case of the network perimeter defence, leaving security holes in a firewall configuration worsens the situation. As for servers, implementing insecure policies or measures that do not harden the server OS, or leaving application exploits unfixed, can cause damage. While dealing with Linux distros, exploits such as buffer overflows and remote command execution are usually used. Typical rudimentary methods such as sending phishing emails, spyware attachments, etc, are used to increase the spread. It is very important to remember that infecting one machine in a network is enough, because that machine, acting as a zombie, can easily replicate the botnet code to other machines in the same network.

Famous botnets

At this point, it is important to mention a few notorious botnets that are still tough to detect.

Conficker: Originally thought to be a virus, Conficker had built-in software routines that could allow the infected machine to be controlled remotely, making it a bot threat. While it was written for Windows OS, a few variants were later created to infect UNIX and Linux systems too. It used the hidden file share vulnerability of Windows to get into the machine, and then turn it into a zombie to spread the infection further. With an infection count of over 10 million machines across the globe, Conficker is still found in systems that are improperly configured, or not protected by a strong perimeter defence system.

Mariposa: This botnet used spyware and malware as a vehicle to inject machines and install a payload of 'command and control centre' modules. The purpose of Mariposa was to run in stealth mode, and keep an eye on passwords and credit card numbers being typed on the machine. It was also programmed to intercept browser requests and lure users to pages hosting updated copies of the botnet itself, as well as advertisement pages.

Srizbi: This botnet was specifically designed to create billions of spam email messages every day. It spread mainly via pirated and free software downloaded on the Net, turning multiple machines into zombies. It had a very small footprint, which made detection very difficult. It had a different control

module by which an infected server would be the owner controlling the zombie army, while other infected servers simply kept a watch on it, and would take over if the controller server failed or shut down. Srizbi is known to have created massive email spam attacks, causing denial of service on mail servers.

Bredolab: This is the most recent botnet army, which infected over 20 million machines worldwide. While the main purpose was to create massive email spam, this botnet also incorporated spyware and viruses in its payload. It is known to infect various Linux distros, and deploy root-kits on those to run in stealth mode. It was dismantled by law authorities, but is believed to still exist in the form of variants.

Protecting FOSS systems

As we learnt, botnets exploit all possible vulnerabilities and create their own eco-system for malicious purposes. While botnets are difficult to detect and tackle, there are a few preventive mechanisms that all network administrators should adopt in their infrastructure. The first and foremost is the perimeter defence system. A properly configured router and firewall must be in place, and the firewall should be configured with auto-updating anti-spam filters. As for physical security, disabling USB and CD drives would help to a great extent. It is important for Linux administrators to know that Linux distros are not secure from botnets, though the percentage of infection is somewhat lower than Windows machines. For FOSS systems, performing a rigorous routine check for root kits and malware is a must. Linux systems, which typically host Web servers and FTP farms, are usually the first targets to deploy the payload. Strengthening and locking file systems is advised too.

Attackers who plan to inject a botnet can use simple methods of breaking into authentication systems, via SSH protocol or over the Web. Thus, using a strict and complex password scheme is very important. The common practice of running unnecessary services on a production Linux server should be discouraged, as it opens up stray ports that are left unmonitored and thus become a back-door for attackers. Just to summarise, cyber security is all about processes and practices, rather than just products. Hence, understanding how botnets attack is imperative for systems administrators to devise a security strategy based on their particular network scenarios. 

By: Prashant Phatak

The author has over 20 years of experience in the field of IT hardware, networking, Web technologies and IT security. Prashant is MCSE and MCDBA certified and is also a F5 load balancing expert. In the IT security world he is an ethical hacker and Net-forensic specialist. Prashant runs his own firm named Valency Networks in India (<http://www.valencynetworks.com>) providing consultancy in IT security design, security audits, infrastructure technology and business process management. He can be reached at prashant@valencynetworks.com.